Identity, Access, API & Security Specification

Authentication, authorization, step-up controls and API behavior

Document status: CURRENT unless otherwise identified | Enterprise delivery assurance training corpus

1. Security Context

Northstar Commerce is preparing a multi-release modernization of its digital commerce platform. This specification is intentionally detailed and includes overlapping business, API, testing, and governance content so that delivery-assurance systems must reason across multiple artifacts rather than rely on one isolated paragraph.

Identity requirements are security-sensitive and should not be inferred from general checkout behavior. Security rules take precedence over convenience when evidence is incomplete.

1.1 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

1.2 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

2. Authentication Contract

Token issuance requires valid credentials and applicable device or risk checks. Repeated failed attempts are rate limited and may trigger additional controls.

Session refresh is permitted only for valid refresh context and must not resurrect a revoked session.

2.1 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

2.2 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

3. Step-Up Authentication

Sensitive administrative or account actions may require step-up authentication. The requirement applies before the protected action is executed, not after.

Scenario	Required Control	Expected Test Evidence
Failed login burst	Rate limit and security event	429/lock outcome + event correlation
Privileged admin action	Step-up authentication	Successful step-up before action
Expired access token	Reject and refresh path	401 then approved refresh behavior
Compromised token	Revoke and deny reuse	Reuse attempt rejected and audited

3.1 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

3.2 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure

behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

4. Authorization and Failure Modes

The API must distinguish unauthenticated, unauthorized, locked, throttled, and validation outcomes. Tests should validate both response and audit side effects.

4.1 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

4.2 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks

remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

5. Security Test Expectations

Negative tests should cover expired token, revoked token, insufficient privilege, replay attempt, and burst failure behavior.

5.1 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

5.2 Operational Guidance

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. Teams should distinguish defects in implementation from defects in the requirement itself; the latter may require product clarification before a test oracle can be defined.

Delivery assurance requires a consistent relationship between business intent, implementation evidence, and release decisioning. A requirement is considered ready for verification only when its scope, preconditions, expected behavior, failure behavior, and measurable acceptance conditions are sufficiently clear. Where the specification leaves material ambiguity, the delivery process should record the uncertainty rather than silently infer a business rule. Traceability must be maintained at a level that allows a reviewer to determine which tests provide evidence for each approved requirement and which release risks remain unresolved. The expected evidence includes source references, stable identifiers, ownership, version status, and execution outcomes so that downstream analysis can distinguish current policy from historical guidance.